

Business Management Platform

Authentication, Identity & Recovery Architecture

Version 2.0 — Revised

Author: Maxwell Gachuhi

Security review and revision pass — v2.0

0. Revision Summary

This version incorporates a security review of v1.0. The core architecture — identity separated from business membership, multiple authentication methods per identity, and role-tiered recovery — is unchanged and remains sound. The following controls were added or tightened:

- Google account linking now requires an explicit exact-email-match rule (§5.1), closing an implicit assumption in v1.0.
- Newly linked recovery methods are subject to a cooldown period and trigger immediate cross-channel notification before they become usable for recovery (§10.6), preventing rapid account takeover via a briefly compromised session.
- Administrator Recovery now requires the approving manager to view device, location, and audit context before approving (§8, Method 5), turning approval into an informed decision rather than a favor.
- Account lockout is explicitly scoped to password authentication only — Google Sign-In and Phone OTP remain available on a locked account, preventing deliberate lockout from being used as a denial-of-service attack against operational staff (§10.4).
- A Session & Device Management capability has been added (§10.7), including remote session revocation — necessary given that POS terminals are physical hardware that can be lost or stolen.
- Token lifecycle requirements have been specified: short-lived access tokens, rotating refresh tokens, and full session invalidation on password change (§10.8).
- Phone-based recovery now requires a mandatory cross-channel notification before completing, mitigating SIM-swap risk (§8, Method 2).
- Audit log visibility is explicitly restricted to Owners and Managers of the relevant business (§10.9).
- A consolidated authentication and recovery state model has been added (§16) so every entry point is shown converging on the same membership-resolution pipeline, preventing recovery paths from being implemented as a separate, weaker route.

1. Purpose

This document defines the authentication, identity management, account recovery, and security architecture for the Business Management System (BMS). The objective is to provide a secure yet user-friendly authentication framework that minimizes operational downtime while protecting business data and preventing unauthorized access.

Unlike traditional systems that rely solely on email and password authentication, the BMS adopts an identity-centric authentication model, allowing users to securely access multiple businesses using a single identity while supporting multiple authentication methods.

2. Design Objectives

- Provide secure authentication for all users.
- Support Single Sign-On (Google OAuth).
- Support multiple businesses under one identity.
- Allow rapid recovery for operational users such as cashiers, without that speed becoming an exploitable weakness.
- Reduce reliance on administrators for password recovery.
- Maintain comprehensive audit trails, with access to those trails restricted by role.
- Protect against account takeover attacks, including attacks that exploit the recovery paths themselves.
- Scale from small businesses to enterprise organizations.

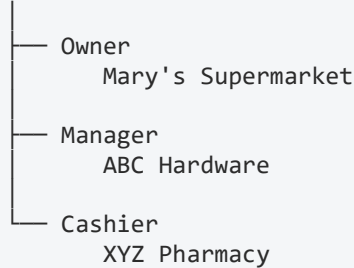
3. Core Design Principles

The authentication subsystem is built upon seven principles.

Principle 1 — Identity is Separate from Business Membership

A user's identity exists independently of any business. One person may belong to multiple businesses while maintaining a single login identity.

Maxwell Gachuhi



This architecture eliminates duplicate accounts and enables seamless switching between businesses.

Principle 2 — Multiple Authentication Methods per Identity

Each identity may have multiple authentication methods linked to it: Password, Google, Phone Verification, and Recovery Codes. Users may authenticate using any configured method.

Principle 3 — Authentication Proves Identity

Authentication methods verify who the user is. Authorization separately determines which business the user belongs to, which branch they can access, which role they possess, and which permissions they receive. Authentication never determines permissions.

Principle 4 — Business Membership Determines Access

After authentication, the backend retrieves all memberships associated with the authenticated identity, then resolves Business, Branch, Role, and Permissions in sequence. This enables one login to support multiple organizations.

Principle 5 — Progressive Security

Recovery methods should be no easier than normal authentication. Each recovery mechanism must provide sufficient proof of ownership before account access is restored.

Principle 6 — Operational Continuity

The system is designed so that cashiers can recover access quickly without requiring lengthy administrative intervention, while maintaining strong security controls.

Principle 7 — Recovery Cannot Become an Attack Surface (New)

Every mechanism that exists to restore access must be evaluated as a potential path for an attacker, not only a legitimate user. This principle governs three specific controls introduced in this revision: a cooldown period on newly linked recovery methods, mandatory cross-channel notification before high-risk recovery actions complete, and explicit scoping of account lockout so it cannot be weaponized against the account holder.

4. Supported Authentication Methods

4.1 Email & Password

- Secure password hashing (Argon2id recommended)
- Password complexity validation
- Password expiry policies (optional)
- Password history enforcement (future enhancement)

4.2 Google Sign-In (OAuth 2.0)

Google authentication provides an alternative login mechanism. Google verifies identity, email ownership, device trust, and multi-factor authentication (if enabled). The BMS independently verifies the Google ID Token, its signature, issuer, audience, and expiry. Google authentication does not determine business permissions.

4.3 Phone Verification

Users may verify their identity using a registered phone number, via Phone Number → One-Time Password (OTP) → Password Reset. Phone verification is intended primarily for operational users such as cashiers.

□ Revision — SIM-swap mitigation

Phone-based recovery alone is not resistant to SIM-swap attacks. Completing a password reset via Phone OTP must trigger a mandatory notification to every other linked channel (email, Google) before the reset takes effect, giving the legitimate owner a chance to intervene.

4.4 Recovery Codes

- Single-use
- Randomly generated
- Offline storage
- Immediately revoked after use

Recovery codes provide access when all other recovery methods are unavailable.

5. Google Sign-In Architecture

Google authentication serves only to verify identity.

```

Landing Page
↓
Continue with Google
↓
Google Authentication
↓
Identity Verified
↓
Load Memberships
↓
Determine Workspace
↓
Dashboard

```

If no memberships exist:

```

Google Login
↓
Identity Created
↓
No Memberships
↓
Business Onboarding

```

5.1 Google Account Linking Rule (New)

A Google account may only be linked to an existing identity, including an invited-but-not-yet-activated identity, when the email address on the Google ID Token exactly matches the identity's registered email. This is not optional and must be enforced server-side against the verified token claim, not client-supplied input.

Where the two addresses do not match — for example, an employee invited at a company email address who only holds a personal Google account — linking must go through an explicit confirmation step rather than an automatic match, since it effectively asserts that an external account should be trusted as that employee's identity.

6. Business Membership Resolution

After authentication the backend determines where the user should be directed.

Scenario 1 — No memberships

```

Authentication
↓
No Business
↓
Create Business

```

Scenario 2 — Single membership

```

Authentication
↓
One Business
↓
Dashboard

```

Scenario 3 — Multiple memberships

```

Authentication
↓
Multiple Businesses
↓
Choose Workspace
↓
Dashboard

```

7. Account Recovery Centre

Instead of a simple "Forgot Password" page, the BMS provides a centralized Account Recovery Centre. Users may recover their account using any configured recovery method; unavailable methods are automatically hidden.

- Continue with Google
- Recover using Phone
- Recover using Recovery Code
- Recover using Employee ID

8. Password Recovery Methods

Method 1 — Google Authentication

```

Continue with Google

```

↓
 Identity Verified
 ↓
 Reset Password (optional)
 ↓
 Dashboard

No email confirmation is required, provided the Google account was linked under the exact-match rule in 5.1 — this precondition is what makes skipping email confirmation safe.

Method 2 — Phone Verification

Registered Phone
 ↓
 OTP
 ↓
 Notify other linked channels
 ↓
 Create New Password
 ↓
 Dashboard

Method 3 — Recovery Codes

Recovery Code
 ↓
 Validate
 ↓
 Create New Password
 ↓
 Dashboard

Method 4 — Employee Recovery

Employee ID
 ↓
 Locate Identity
 ↓
 Phone OTP
 ↓
 Reset Password

Employee ID alone never grants access.

Method 5 — Administrator Recovery (Last Resort)

Recovery Request
 ↓
 Manager reviews device, location & audit context
 ↓
 Manager Approval
 ↓
 Identity Verification
 ↓
 Temporary Recovery Link
 ↓
 Password Reset

Administrator recovery is intended only when all self-service recovery options fail.

□ Revision — informed approval

v1.0 required only "Manager Approval" as a bare request. This revision requires the approving manager to be shown the same device, location, and audit metadata the system already collects (§10.9) at the point of approval, so approval is an informed security decision rather than a favor granted to a colleague.

9. Forgot Email Recovery

Users who cannot remember their login email may recover it through alternative identifiers. The email address is displayed only after successful identity verification.

```

Business Name
↓
Employee ID
↓
Phone Number
↓
Verify Identity
↓
Display Registered Email
↓
Continue Login

```

10. Security Measures

10.1 Identity Verification

- Verified Google ID Tokens
- Email verification
- Phone verification
- Recovery codes
- Identity confirmation before password reset

10.2 Password Security

- Argon2id hashing
- Minimum password complexity
- Password confirmation
- Password reuse prevention (future)
- Secure password reset tokens

10.3 Rate Limiting

- Login attempts
- OTP requests
- Password reset requests
- Recovery requests

10.4 Account Lockout

Temporary lockout after repeated failed authentication attempts — for example, 5 failed logins triggers a 15-minute lock.

□ Revision — lockout scope

Lockout applies only to email/password authentication on the affected account. Google Sign-In and Phone OTP remain available on a locked account. Without this scoping, an attacker (or anyone else) could deliberately lock out a cashier mid-shift simply by entering an incorrect password five times, directly undermining Principle 6 (Operational Continuity).

10.5 Device Awareness

The system records browser, operating system, device, IP address, and approximate location, used for anomaly detection and security notifications.

10.6 Recovery Method Cooldown

Newly linked recovery methods — a new phone number, a new Google account, or newly generated recovery codes — cannot themselves be used to perform a recovery for a cooldown window (recommended 24–48 hours) after linking. Linking any new recovery method triggers an immediate notification to every other channel already on file. This prevents an attacker who briefly compromises a session from linking their own recovery method and using it moments later to lock out the legitimate owner.

10.7 Session & Device Management

Users, and managers acting on behalf of a cashier, can view a list of active sessions with device, location, and last-active timestamp, and revoke any session remotely. This is necessary because POS terminals are physical hardware that can be lost, stolen, or left logged in at an unattended counter.

10.8 Token Lifecycle

- Access tokens are short-lived (minutes, not hours).
- Refresh tokens rotate on every use; reuse of a superseded refresh token invalidates the entire session chain.
- All active sessions and tokens are invalidated the moment a password is changed through any method, including recovery — closing the gap where a successful Administrator Recovery reset could otherwise leave an attacker's existing session alive.

10.9 Audit Logging

Every authentication event is recorded — for example, a password change via Google Authentication on a Windows Desktop in Nairobi, with date and time.

□ Revision — audit log access control

Audit logs are visible only to Owners and Managers of the business the record belongs to. A Cashier's own authentication history is not exposed to peers, and cross-business visibility is never granted regardless of role.

10.10 Security Notifications

- Password changes
- New Google account linked
- Phone number changes
- Login from new device
- Recovery code usage
- Successful account recovery

11. Role-Based Recovery Policies

Recovery requirements vary according to user privilege. Higher-privilege accounts intentionally have fewer weak-factor options, not more — Business Owners are excluded from Phone OTP recovery because phone numbers are vulnerable to SIM-swap attacks and Owner accounts represent the highest-value target.

Role	Recovery Methods
Cashier	Password, Google, Phone OTP
Manager	Password, Google, Phone OTP, Recovery Code (optional)
Business Owner	Password, Google, Authenticator App (future), Recovery Codes

12. Threat Mitigation

Threat	Mitigation
Brute-force login	Rate limiting, account lockout (password auth only — see 10.4)
Password theft	Google Sign-In, password hashing
SIM swap attack	Recovery codes, Google authentication, mandatory cross-channel notification (8, Method 2)
Employee ID guessing	Secondary verification required
Session hijacking	Secure JWT tokens, HTTPS, short-lived access tokens, refresh token rotation (10.8)
Account takeover	Audit logs, recovery notifications, recovery-method cooldown (10.6)
Unauthorized password reset	Identity verification before reset
Denial of service via lockout (New)	Lockout scoped to password auth only; Google/Phone OTP remain available (10.4)
Stale session after recovery (New)	All sessions invalidated on any password change (10.8)
Social-engineered admin approval (New)	Manager sees device/location/audit context before approving (8, Method 5)

13. Recommended User Onboarding Security

During account creation users should be encouraged to configure additional recovery methods.

- Link Google Account
- Verify Phone Number
- Generate Recovery Codes

This improves long-term account recoverability.

14. Future Enhancements

- Microsoft Azure AD Sign-In
- Passkeys (WebAuthn/FIDO2)
- Authenticator Apps (TOTP)
- Biometric Authentication
- Adaptive Risk-Based Authentication
- Single Sign-On (SSO) for enterprise organizations
- Hardware Security Keys

15. Conclusion

The proposed authentication and recovery architecture balances security, usability, and operational continuity. By separating identity from business membership and supporting multiple authentication and recovery methods, the Business Management System enables users to regain access quickly while maintaining strong protection against unauthorized access.

This design is particularly suited to retail and SME environments where minimizing downtime is critical. Cashiers can recover access rapidly through trusted self-service methods, while higher-privilege accounts benefit from additional safeguards appropriate to their level of access. This revision closes the gaps where rapid recovery could otherwise be turned against the account holder — recovery-method cooldowns, scoped lockout, informed administrator approval, and session invalidation on reset — without adding friction to the legitimate recovery paths the system was built to provide.

16. Consolidated Authentication & Recovery State Model (New)

Every entry point described in this document — standard login, Google Sign-In, and all five recovery methods — converges on the same pipeline once identity is established. No entry point, including recovery, is permitted to reach a workspace by any other route.

```
Any Entry Point
(Password / Google / Phone OTP / Recovery Code / Employee ID / Admin Recovery)
↓
Identity Verified
↓
Load Memberships
↓
Determine Workspace
↓
Dashboard
```

This guarantees that recovery can never become a shortcut around membership resolution or role assignment — every path, however a user arrives, is resolved identically from the moment identity is confirmed.